

TTRTECHNOLOGY

Mastering CIS Top 20

CRITICAL SECURITY CONTROLS

A Comprehensive Guide

(866)-217-7225 INFO@TTRTECHNOLOGY.COM TTRTECHNOLOGY.COM

CIS Top 20 Critical Security Controls

The CIS Top 20 Critical Security Controls—formerly known as the SANS Top 20—provide a comprehensive, prioritized framework for mitigating known cyber threats. Developed by a global consortium of cybersecurity experts, these controls go beyond general best practices by offering a structured, actionable approach to improving organizational security posture.
Organized into three categories—Basic, Foundational, and Organizational—the controls help organizations build security maturity in a progressive, strategic manner:

- **Basic Controls (1–6):** These form the essential foundation, offering key defenses every organization should implement first.

- **Foundational Controls (7–16):** These address more complex risks and infrastructure-focused measures.

- **Organizational Controls (17–20):** These focus on people, processes, and long-term governance strategies.

These controls serve as a tactical roadmap, applicable across industries and business sizes. Rooted in NIST SP 800-53 and aligned with other leading frameworks, the CIS Controls integrate threat intelligence to drive risk-informed decision-making. By systematically applying all 20 controls, organizations can significantly reduce their exposure to cyberattacks, while also lowering operational and remediation costs.

However, it’s important to move beyond a checklist mentality. True value comes from embedding these controls into a holistic risk management strategy. When fully embraced, the CIS Controls not only enhance resilience but also build a proactive culture of cybersecurity.

Summary:

Basic 5

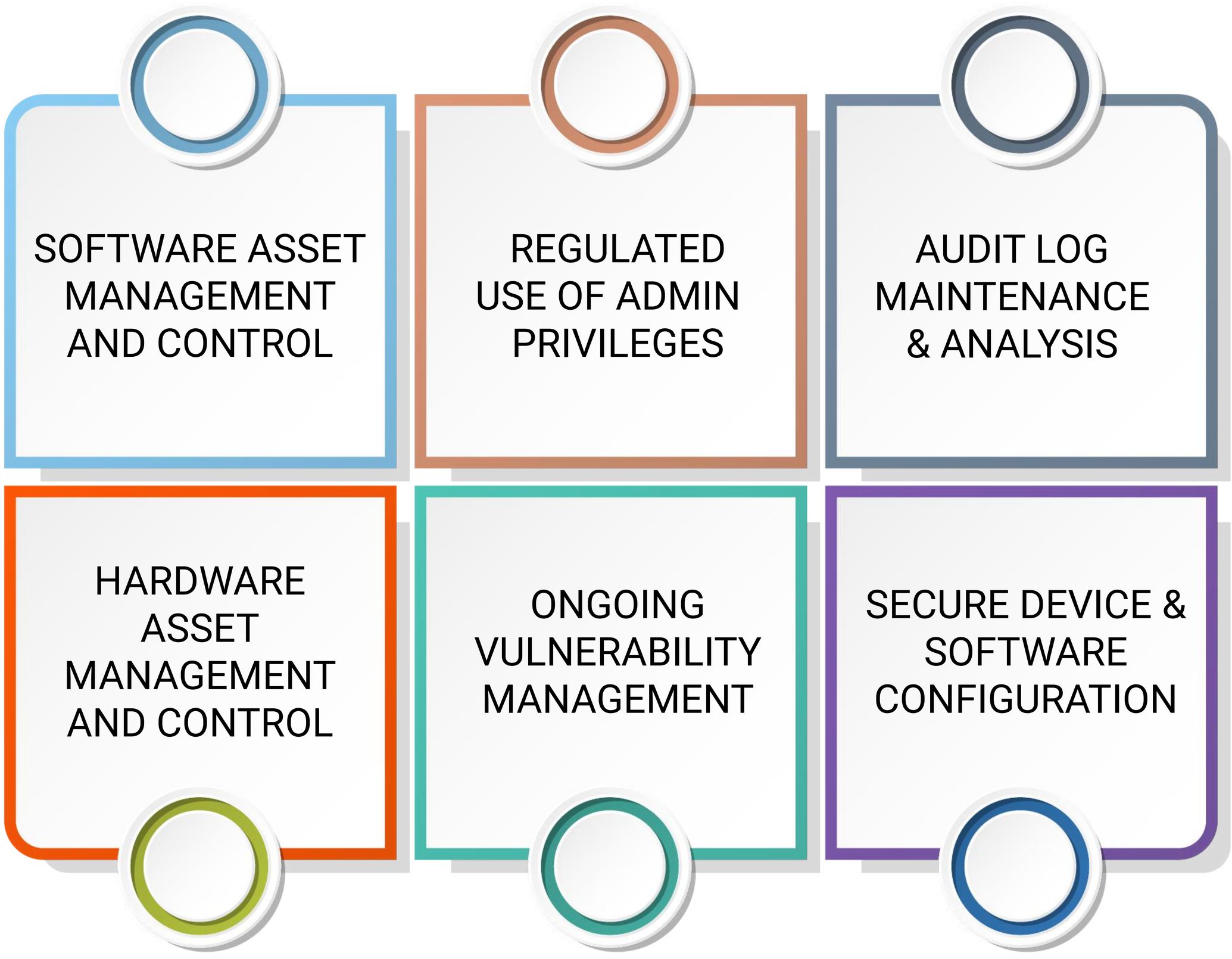
CONTROL 1: Hardware Asset Management and Control
CONTROL 2: Software Asset Management and Control
CONTROL 3: Ongoing Vulnerability Management
CONTROL 4: Regulated Use of Admin Privileges
CONTROL 5: Secure Device & Software Configuration
CONTROL 6: Audit Log Maintenance & Analysis

Foundational 11

CONTROL 7: Email & Browser Safeguarding
CONTROL 8: Malware Defenses
CONTROL 9: Port, Protocol, and Service Control
CONTROL 10: Data Recovery
CONTROL 11: Network Device Secure Configuration CONTROL 12: Boundary Defense
CONTROL 13: Data Protection
CONTROL 14: Need-to-Know Access Control
CONTROL 15: Wireless Access Control
CONTROL 16: Account Monitoring and Control

Organizational

CONTROL 17: Security Awareness and Training Program
CONTROL 18: Security Awareness and Training Program
CONTROL 19: Incident Response and Management
CONTROL 20: Penetration Tests and Red Team Exercises



Basic 5

Control 1: Hardware Asset Management and Control

Overview: To maintain strong security, organizations must maintain visibility and control over all devices connected to their networks. Identifying and authorizing devices prevents unauthorized access and lays the foundation for other security measures.

Implementation Guide:

- Use inventory tools like Microsoft SCCM integrated with network access control systems.
- Leverage DHCP logging to track device connections.
- Integrate DHCP logs with SIEM for enhanced correlation.
- Utilize alternative system discovery tools if SCCM is unavailable.

Key Benefit:

Provides a clear device inventory, optimizing security with minimal effort from small IT teams.

Control 2: Software Asset Management and Control

Overview: Tracking software assets and restricting unauthorized applications helps prevent malicious installations and ensures faster incident response.

Implementation Steps:

- Restrict User Rights: Limit Local Administrator access to essential users only.
- Establish Software Policies: Start with a denylist and evolve to a whitelist of approved applications.
- Centralized Management: Use SCCM, FootPrints, or Windows policies to scan, remove, and track software.
- Verify Software Integrity: Use built-in OS tools or endpoint security platforms to ensure only trusted software is allowed.

Interdependencies:

Supports Controls 7 (Email/Web Protections), 8 (Malware Defenses), and 13 (Data Protection).

Control 3: Ongoing Vulnerability Management

Overview: Identifying and mitigating vulnerabilities before attackers can exploit them is essential.

Key Practices:

- Conduct weekly scans (internal & external).
- Log, monitor, and archive all scan results.
- Correlate logs with security events.
- Prioritize vulnerabilities using:
  a. Asset criticality
  b. Likelihood of exploitation
  c. Potential business impact
- Remediate using patch management tools and re-scan to validate fixes.

Control 4: Regulated Use of Administrative Privileges

Overview: Administrator privileges are a common attack vector. Minimizing and managing these privileges reduces exposure.

Implementation Guide:

- Review admin task requirements and reduce unnecessary privileges.
- Promote least privilege use and separation of accounts.
- Educate users, especially executives, on the risks.

Technical Controls:

1. Change default passwords.
2. Use multifactor authentication for admins.
3. Require long passwords (14+ characters).
4. Set alerts for failed admin logins.
5. Use separate devices or air-gapped systems for admin tasks if possible.

Control 5: Secure Device & Software Configuration

Overview: Default configurations favor usability over security. Tightening these settings helps minimize vulnerabilities.

Implementation Steps:

- Define strict baseline configurations and adjust as needed.
- Disable unnecessary services and ports on older systems.

Frameworks & Tools:

- NIST 800-70 rev 3
- National Vulnerability Database
- CIS Benchmarks
- STIG

Sub-Controls:

- Maintain secure templates.
- Store configurations on monitored servers.
- Regularly enforce and validate using SCAP-compliant tools.

Control 6: Audit Log Maintenance & Analysis

Overview: Monitoring and analyzing logs is key to detecting threats and incidents.

Implementation Steps:

- **Quick Win:** Sync system time using NTP (e.g., NTP Pool Project).

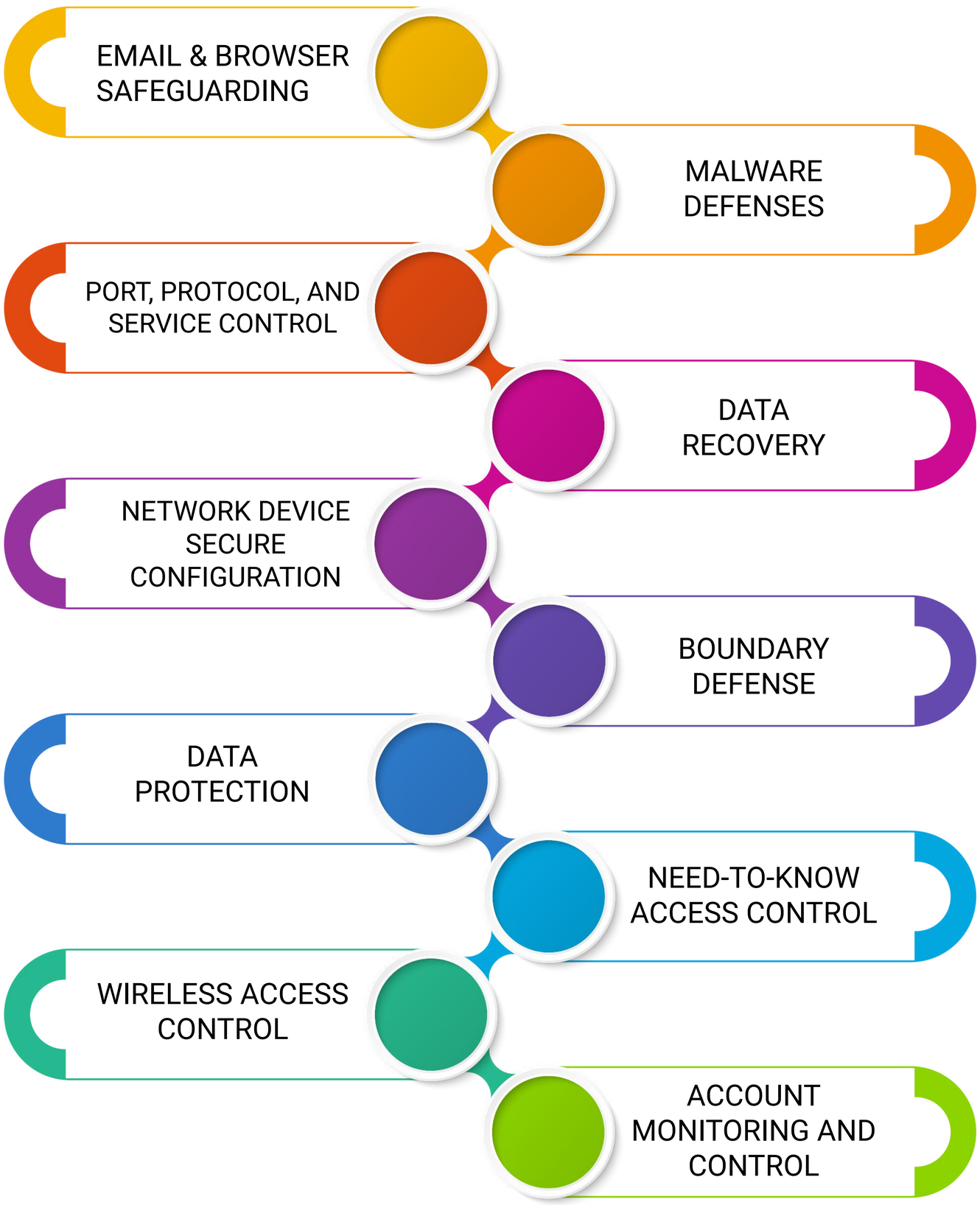
- **Review & Alert:**
  - Conduct weekly log reviews.
  - Customize SIEM alerts to focus on meaningful incidents.

Log Sources:

- Network devices (switches, routers)
- Security platforms (IDS/IPS, anti-malware)
- Servers (app, database, web)
- Workstations

References:

- SANS Log Management Strategies
- NIST SP 800-92
- Malware Archeology



Foundational 11

Control 7: Email & Browser Protection

Workstations are a common target for attackers. This control focuses on protecting users from threats delivered through email and web browsers.

How to Implement:

- **Filter Email Content:** Block risky email attachments and apply filtering at the server level to catch threats early.
- **Use SPF Records:** Set up Sender Policy Framework (SPF) on your DNS and mail servers to reduce spoofed and malicious emails.
- **Secure Browser Settings:** Disable unneeded plugins and restrict unknown scripts. Keep settings simple for users to reduce the chance of workarounds.

Control 8: Malware Defense

This control helps protect your systems from malware across endpoints, infrastructure, and IoT devices. Antivirus tools still matter, but modern defenses go beyond that.

How to Implement:

- **Centralize Malware Logs:** Automate log collection to detect incidents quickly.
- **Keep Incident Records:** Maintain logs to better understand internal activity.
- **Mandatory Antivirus:** Require antivirus on every device in your network.
- **Scan Removable Media:** Block unauthorized installations and scan USBs and drives.
- **Monitor for Threats:** Use network monitoring and intrusion detection tools to spot malware behavior.

Control 9: Port, Protocol & Service Control

This control ensures you only allow required network communications, reducing exposure and entry points for attackers.

How to Implement:

1. **Perform Port Scans:** Scan your environment before and after software is installed.
2. **Use Host-Based Firewalls:** Only allow required services and block the rest.
3. **Continuously Scan Your Network:** Identify new services or open ports regularly

4. **Audit External IPs:** Check for unknown or misconfigured exposed systems.
5. **Isolate Critical Services:** Separate high-value systems from less sensitive areas.
6. **Use Application Firewalls:** Place them in front of important servers to filter traffic.

Control 10: Data Recovery

Ensure that critical data is backed up and can be restored quickly if lost or tampered with by cyberattacks or system failure.

How to Implement:

- **Automate Backups:** Regularly back up sensitive data.
- **Test Restores:** Regularly verify that backups work and data can be restored properly.
- **Encrypt Backups:** Keep backups secure, both physically and digitally.
- **Restrict Access:** Make sure backup destinations are not accessible through normal OS paths.

Control 11: Secure Network Device Configuration

Protect your firewalls, routers, and switches by setting strong, standardized configurations and monitoring them for unauthorized changes.

How to Implement:

- **Use Standard Configs:** Align network devices to approved security baselines.
- **Track Changes:** Log every config change with the person, reason, and duration.
- **Detect Unauthorized Edits:** Use tools to monitor and report config changes.
- **Use Strong Authentication:** Enforce MFA and avoid unsecure access methods like Telnet.
- **Keep Devices Updated:** Patch devices promptly and use automated patching where possible.
- **Use Separate Admin Devices**: Manage devices from locked-down machines used only for admin tasks.
- **Isolate Admin Traffic:** Keep network management traffic separate from business traffic.

Control 12: Boundary Defense

Defend your network perimeter and control what enters and exits. Layered defenses help block threats before they reach internal systems.

How to Implement:

- **Segment the Network:** Create DMZs and use firewalls and proxies to filter traffic.
- **Monitor and Log:** Capture firewall, IDS/IPS, and DMZ logs in a SIEM system for analysis.
- **Control Remote Access:** Require current security patches and MFA for anyone connecting remotely.

Control 13: Data Protection

Protect data in line with legal, regulatory, and business requirements. This includes understanding, classifying, and controlling data access.

How to Implement:

- **Set Policies:** Define what types of data you store, how they're classified, and how long they should be kept.
- **Follow Procedures:** Make sure sensitive data is routed and stored properly.
- **Apply Technical Controls:** Use encryption, block risky websites and USB use, and implement DLP and PAM tools.

Control 14: Need-to-Know Access

Only give access to sensitive systems and data when it's necessary for someone's job. This principle reduces the damage possible from compromised accounts.

How to Implement:

- **Classify Data:** Use categories like Public, Internal, Confidential, and Highly Sensitive.
- **Segment the Network:** Put sensitive systems on isolated VLANs with firewall protections.
- **Use Access Lists:** Apply and audit ACLs, and enforce least privilege or role-based access.
- **Encrypt Sensitive Data:** Encrypt in transit and at rest, with extra steps for critical data.
- **Archive Old Data:** Move unused data to secure archives after a set period.

Control 15: Wireless Access Control

Secure your wireless networks to keep attackers from exploiting them to reach your internal systems.

How to Implement:

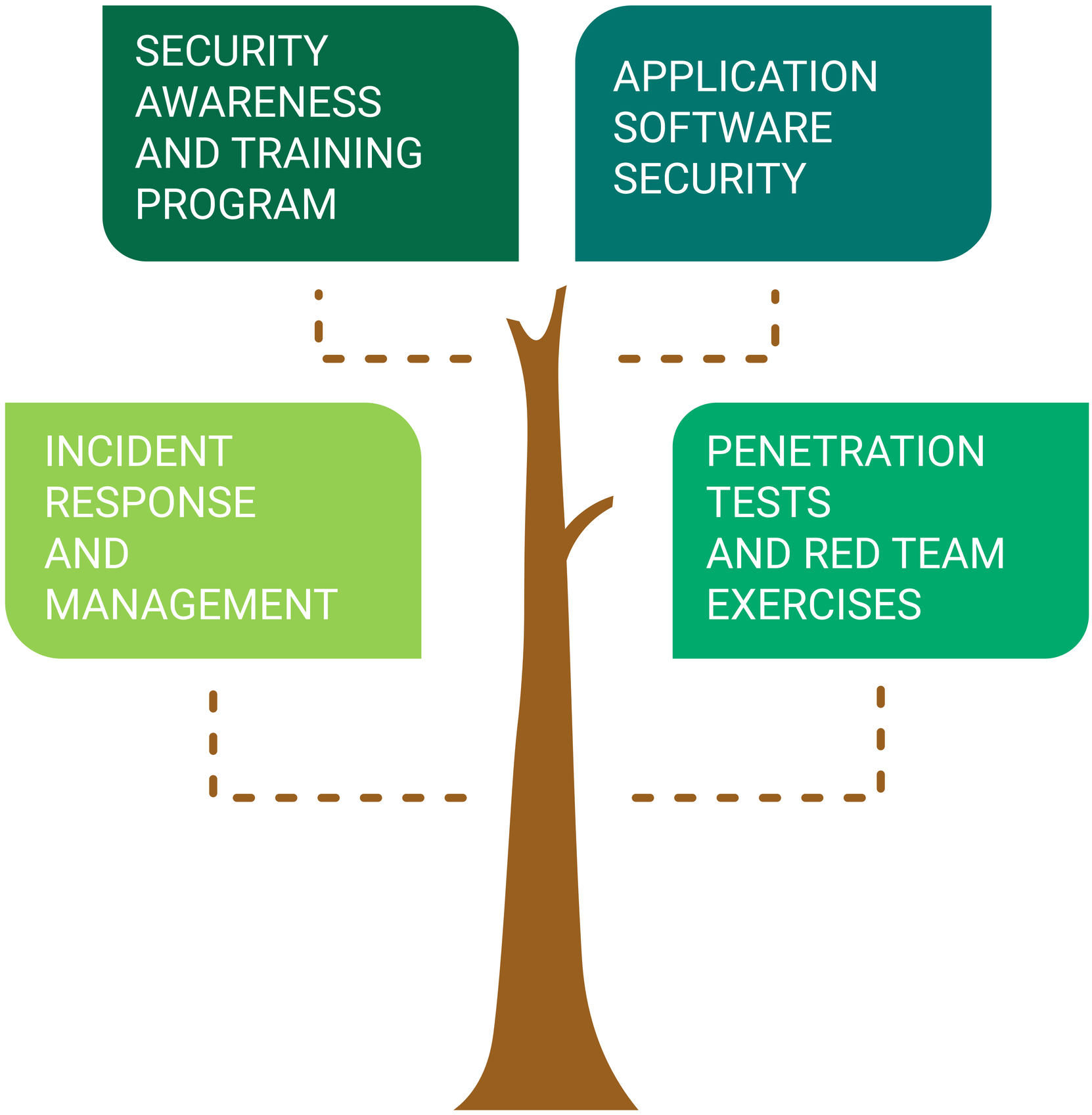
- **Hide Your SSID:** Make your network less visible to casual threats.
- **Use Certificates:** TLS certificates help prevent fake access points.
- **Apply WPA2-Enterprise:** Authenticate users individually through RADIUS.
- **Limit Broadcast Range:** Keep signal strength inside your premises.
- **Check for Rogue Devices:** Regularly scan for unauthorized access points.
- **Create a Guest Network:** Isolate visitors from your main systems.
- **Log Wireless Devices:** Keep records to track activity and investigate incidents.

Control 16: Account Monitoring & Control

Properly manage user accounts throughout their lifecycle to avoid unauthorized access.

How to Implement:

- **Work with HR:** Update or remove accounts quickly when employees change roles or leave.
- Set Device Policies:
  - Auto logoff on inactivity
  - Enable lock screens
  - Disable dormant accounts
  - Use account lockouts
  - Set account expiration dates
- **Centralize Authentication:** Use tools like LDAP to manage access.
- **Enforce 2FA:** Especially for admins, sensitive systems, and remote access.



Control 17: Security Awareness & Training Program

Even if employees know the basics, many are unaware of current threats or how their actions impact cybersecurity. This control helps build a culture of security across your organization.

How to Implement:

- **Start with the Basics:** Provide new hires with an overview of IT policies and safe usage practices. Send out annual reminders and keep materials updated to reflect new threats.
- **Offer Ongoing Training:** Use video lessons, interactive sessions, and newsletters to educate staff on current topics like phishing, password safety, secure data handling, and device usage.
- **Make It Relevant:** Tailor training to your business needs. For example, if you're in healthcare, include HIPAA-specific modules. Provide role-based sessions and require participation.
- **Encourage Reporting:** Create a supportive environment where employees feel comfortable reporting suspicious activity. Use clear, open communication channels with your IT team.
- **Promote Awareness Creatively:** Use posters, quizzes, and even small rewards to keep cybersecurity top-of-mind.

Control 18: Application Software Security

This control focuses on identifying and fixing security issues in applications—whether you build or buy them—throughout the software development lifecycle.

How to Implement:

- **Collaborate with Teams:** Involve developers, IT, procurement, and compliance early on. Understand how applications are developed or sourced and where the biggest risks lie.
- **Build Security into Development:** Don’t wait until the end of a project. Add security checks at every phase—design, coding, testing, and deployment.
- **Empower with Tools and Training:** Assign security champions from your development teams. Equip them with tools like static analysis scanners, WAFs (Web Application Firewalls), and training to support secure coding practices.
- **Review Third-Party Code:** Audit third-party libraries or purchased software to ensure they meet your organization’s security standards.

Control 19: Incident Response & Management

When a cyberattack happens, how you respond can make all the difference. This control helps you prepare and react efficiently to minimize damage.

How to Implement:

- **Create an Incident Response Plan (IRP):** Document your process for handling different types of threats—ransomware, DDoS attacks, data breaches, and more. Review and update it regularly.
- **Build a Response Team:** Identify key players—security analysts, IT leads, legal counsel, HR, and PR. Assign clear roles and train them for incident handling.
- **Run Drills and Tests:** Conduct tabletop exercises and simulations to keep your team prepared and spot weaknesses in your plan.
- **Make Reporting Easy:** Educate employees on what to look out for (e.g., phishing attempts) and how to report issues quickly. Include this in ongoing awareness training.
- **Keep Communication Flowing:** Define how and when to communicate internally and externally during an incident to avoid confusion and preserve trust.

Control 20: Penetration Tests & Red Team Exercises

This control pushes organizations to test their defenses under real-world conditions by simulating cyberattacks.

How to Implement:

- **Define the Scope:** Decide whether to test your entire network, a specific application, internal controls, or your team's detection and response abilities. Set clear goals and boundaries.
- **Plan the Details:** Ask important questions—What systems are off-limits? Should testers use social engineering? Will it be a one-time test or ongoing assessments?
- **Protect Your Systems:** Ensure testing doesn't disrupt business. Use controlled environments and temporary test accounts. Disable or monitor those accounts after testing ends.
- **Analyze and Act:** Look beyond technical vulnerabilities. Did your team detect the attack? How fast did they respond? Use findings to fix weaknesses in both systems and processes.
- **Schedule Regular Tests:** Make penetration testing a routine part of your security strategy to stay ahead of evolving threats.

Summing It Up

This guide offers a comprehensive look at the CIS Top 20 Critical Security Controls—but remember, it's not about implementing everything at once. The key is understanding which controls best match your organization’s unique needs, goals, and regulatory requirements.

Every business is different. Your security strategy may be driven by compliance mandates, customer data protection, internal policies, or industry-specific risks. These 20 controls serve as a flexible blueprint. Start with the ones that meet immediate legal, operational, or partner obligations. As your security posture matures, the next steps will naturally reveal themselves.

At TTR Technology, we view the CIS Controls as a foundational framework for building strong, scalable cybersecurity programs. Whether you're just beginning or strengthening existing defenses, this guide can help you prioritize, understand, and act with confidence.

ABOUT

TTR TECHNOLOGY

TTR Technology's Comprehensive Guide to CIS Top 20 helps you implement critical security controls, reduce risk, and strengthen your cybersecurity posture. Contact us today and safeguard your business with proven security best practices.





MISSION

TTR Technology provides managed IT services and cybersecurity solutions that protect your data, optimize business operations, and empower you to grow with confidence.

SOLUTIONS

- Innovation
- Support
- Reliability
- Scalability

(866)-217-7225 INFO@TTRTECHNOLOGY.COM TTRTECHNOLOGY.COM